

BÁO CÁO THỰC HÀNH LAB 14

Họ tên : Trần Việt Đức

Mã sinh viên : 20220111

1. Giới thiệu và Mục tiêu bài Lab

Bài lab tập trung tìm hiểu và ứng dụng **Spring Security** vào mô hình Spring Boot MVC để xây dựng hệ thống bảo mật toàn diện. Các mục tiêu chính bao gồm:

Tích hợp thành công spring-boot-starter-security và thymeleaf-extras-springsecurity6 vào dự án Maven.

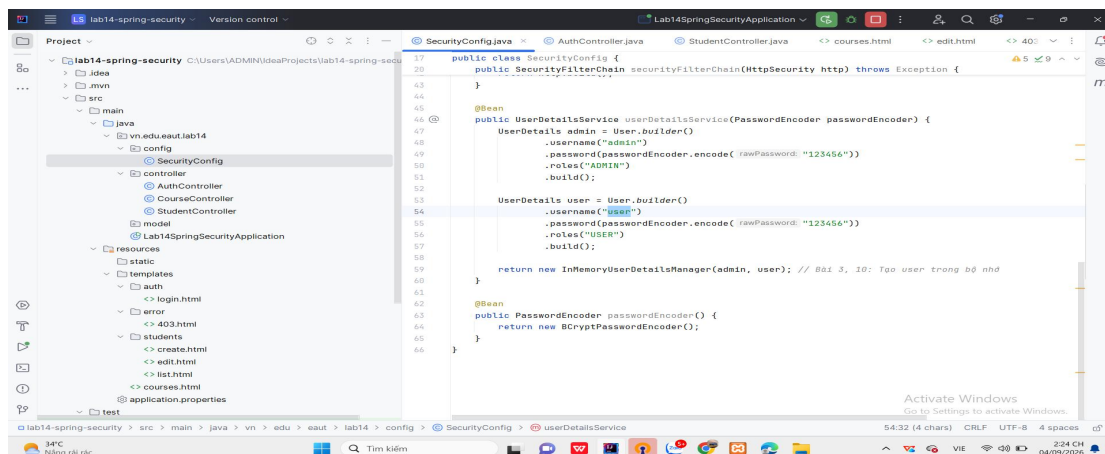
Xây dựng hệ thống xác thực (Authentication) bằng tài khoản lưu trong bộ nhớ (InMemoryUserDetailsService) với hai phân quyền ADMIN và USER.

Phân quyền truy cập URL (Authorization) và bảo vệ các chức năng quản trị nhạy cảm (thêm, sửa, xóa dữ liệu sinh viên và quản lý khóa học).

Tùy chỉnh giao diện đăng nhập (/login), trang xử lý lỗi từ chối truy cập (/403), và sử dụng Thymeleaf Security để ẩn/hiện các thành phần giao diện theo vai trò người dùng.

2. Cấu trúc dự án (lab14-spring-security)

Mã nguồn được tổ chức theo chuẩn cấu trúc của một ứng dụng Spring Boot MVC:



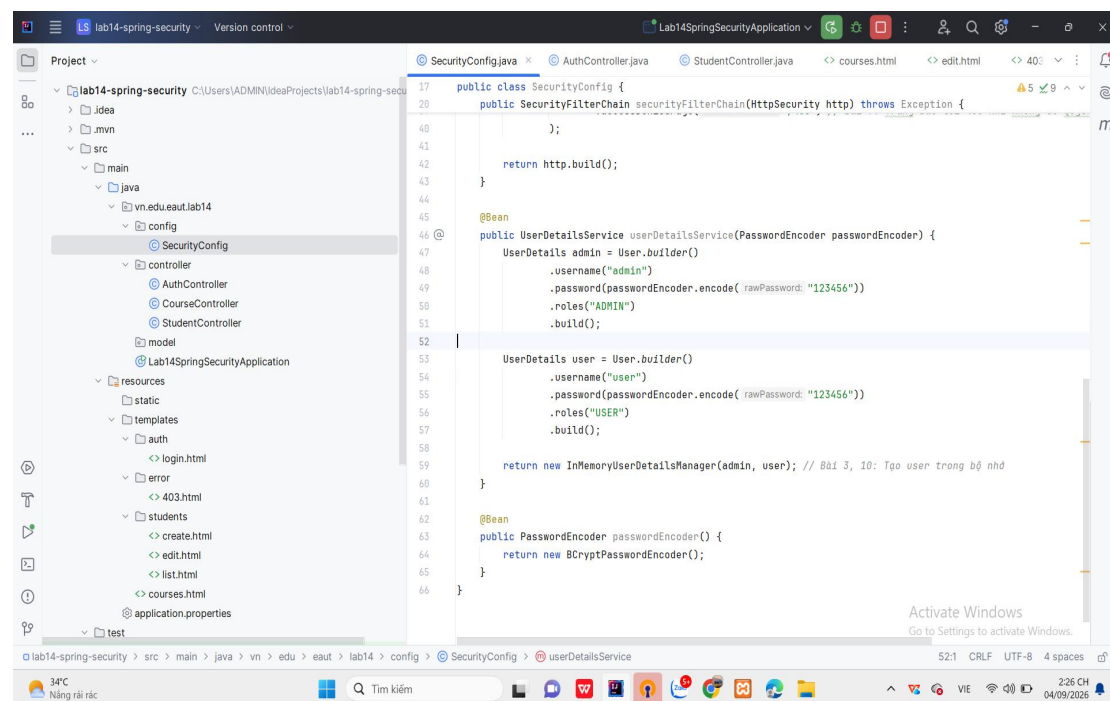
3. Nội dung hiện thực hóa kỹ thuật

3.1. Cấu hình bảo mật hệ thống (SecurityConfig.java)

Thiết lập bộ lọc bảo mật `SecurityFilterChain`, phân định rõ các URL công khai và URL yêu cầu quyền hạn cụ thể, đồng thời định nghĩa thông tin tài khoản mẫu trong bộ nhớ:

Phân quyền URL:

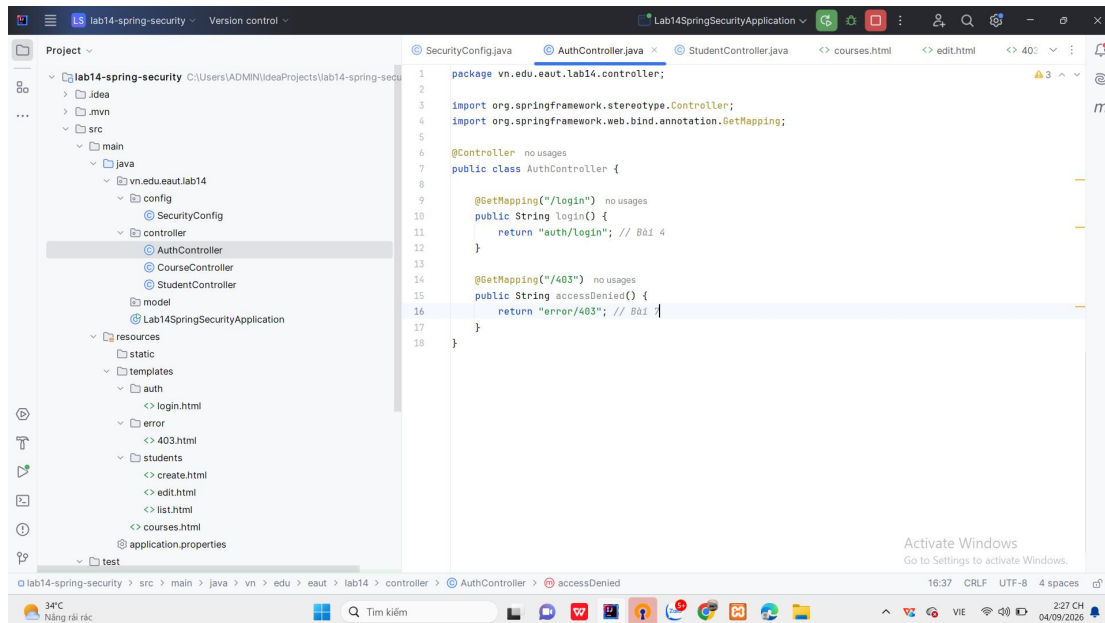
Cấu hình Login/Logout/Exception: Trỏ tới trang đăng nhập tùy chỉnh `/login`, chuyển hướng về `/students` khi thành công, và điều hướng đến trang `/403` khi xảy ra lỗi không đủ quyền hạn truy cập.



Quản lý User: Khởi tạo tài khoản admin (mật khẩu mã hóa 123456, role ADMIN) và user (mật khẩu mã hóa 123456, role USER) sử dụng `BCryptPasswordEncoder`.

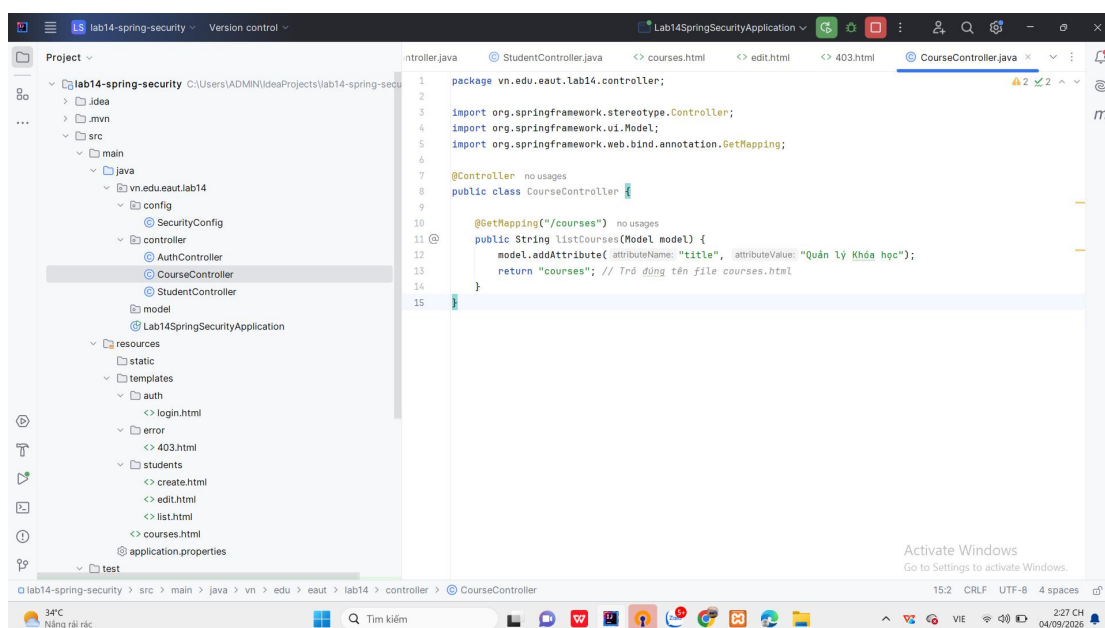
3.2. Các Bộ điều khiển (Controllers)

AuthController.java: Điều hướng request tới trang đăng nhập (auth/login) và trang thông báo lỗi cấm truy cập (error/403)



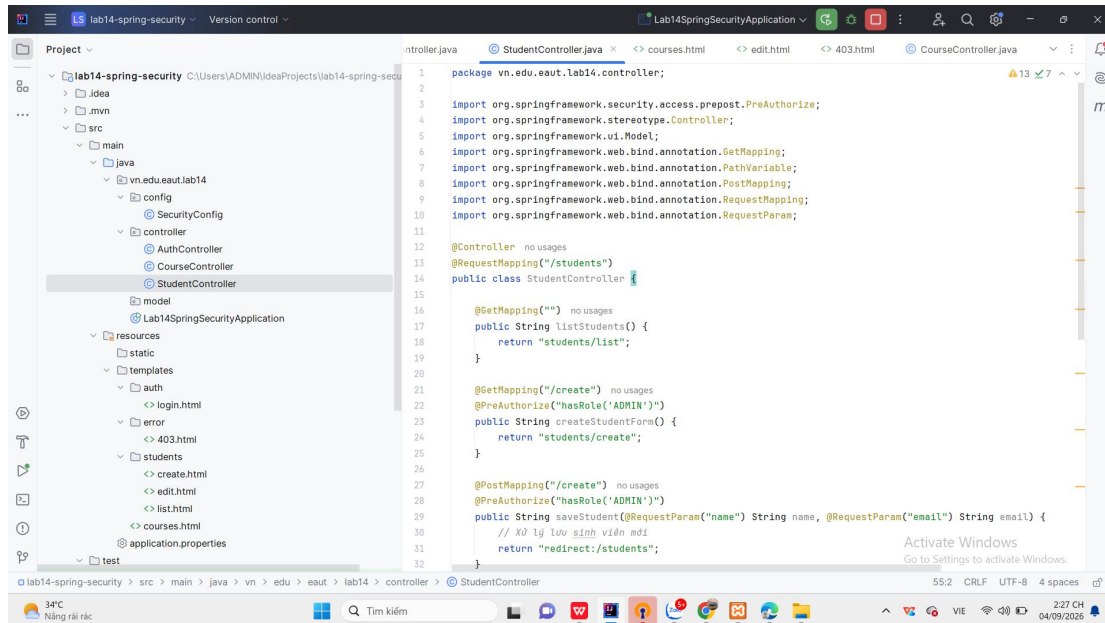
```
1 package vn.edu.eaut.lab14.controller;
2
3 import org.springframework.stereotype.Controller;
4 import org.springframework.web.bind.annotation.GetMapping;
5
6 @Controller
7 public class AuthController {
8
9     @GetMapping("/login")
10    public String login() {
11        return "auth/login"; // Bài 4
12    }
13
14    @GetMapping("/403")
15    public String accessDenied() {
16        return "error/403"; // Bài 4
17    }
18 }
```

CourseController.java: Quản lý đường dẫn /courses dành riêng cho quản trị viên, trả về giao diện quản lý khóa học (courses.html).



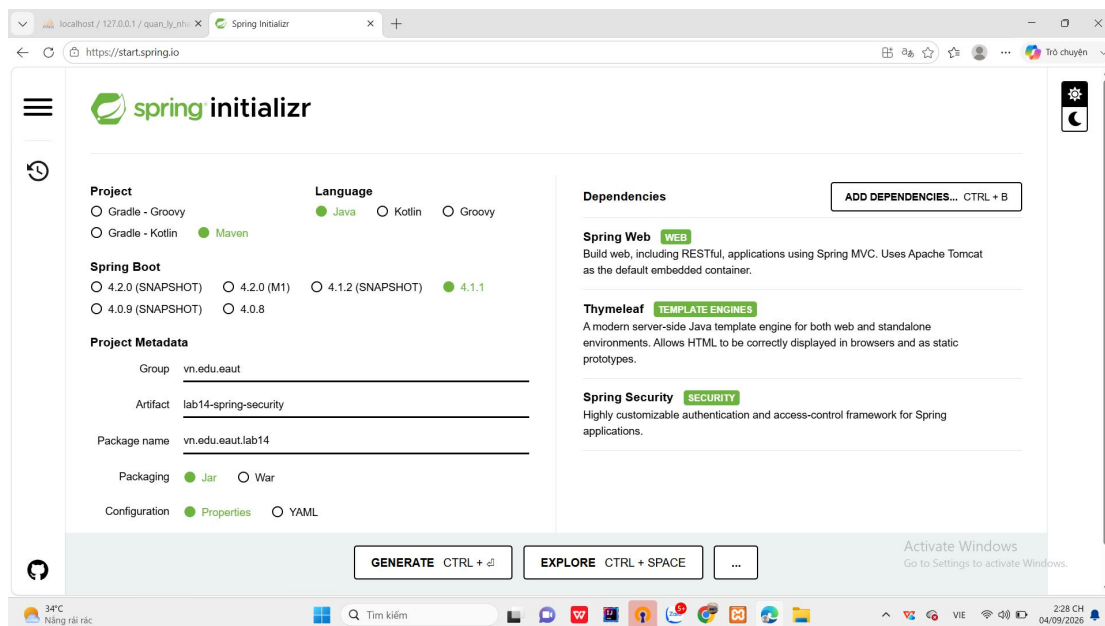
```
1 package vn.edu.eaut.lab14.controller;
2
3 import org.springframework.stereotype.Controller;
4 import org.springframework.ui.Model;
5 import org.springframework.web.bind.annotation.GetMapping;
6
7 @Controller
8 public class CourseController {
9
10    @GetMapping("/courses")
11    public String listCourses(Model model) {
12        model.addAttribute("title", "Quản lý Khóa học");
13        return "courses"; // Trả về tên file courses.html
14    }
15 }
```

StudentController.java: Xử lý các nghiệp vụ liên quan đến sinh viên gồm xem danh sách (/students), hiển thị/xử lý thêm mới (/students/create), chỉnh sửa (/students/edit/{id}) và xóa (/students/delete/{id}) với cơ chế bảo mật phương thức @PreAuthorize("hasRole('ADMIN')").



3.3. Giao diện người dùng và Thymeleaf Security

Sử dụng thư viện thymeleaf-extras-springsecurity6 để kiểm soát hiển thị giao diện động:

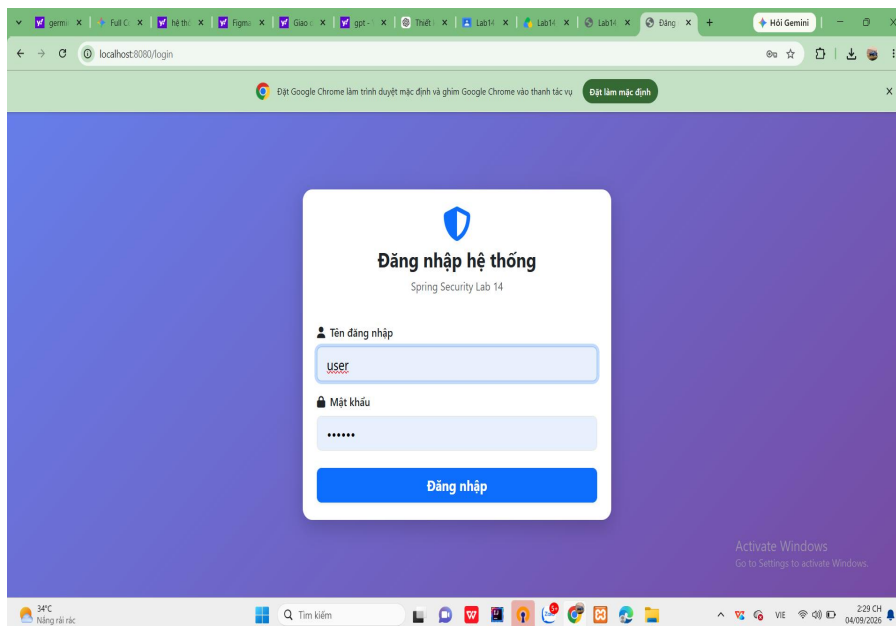


Kiểm tra trạng thái đăng nhập (`sec:authorize="isAuthenticated()"`) để hiển thị tên tài khoản hiện tại và nút đăng xuất.

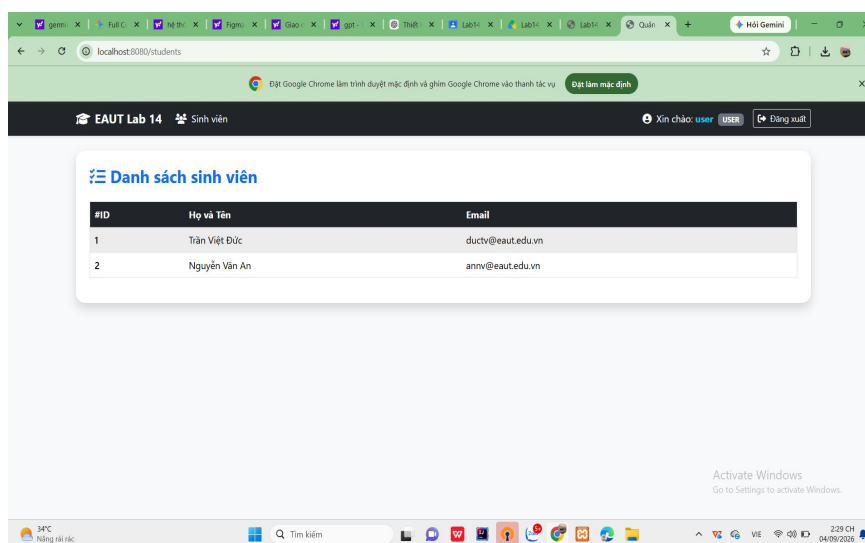
Ẩn hoặc hiện các nút chức năng quản trị (Thêm, Sửa, Xóa) và menu "Khóa học (Admin)" dựa vào điều kiện vai trò `sec:authorize="hasRole('ADMIN')"`.

4. Kết quả kiểm thử và Minh chứng thực tế

Đăng nhập với tài khoản user:

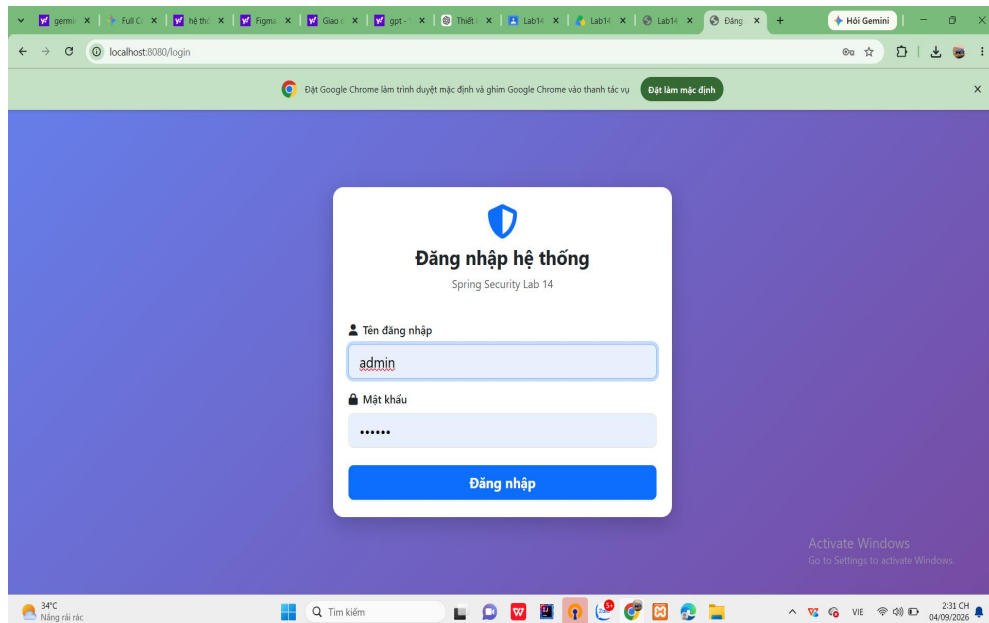


Giao diện chỉ hiển thị danh sách sinh viên cơ bản.

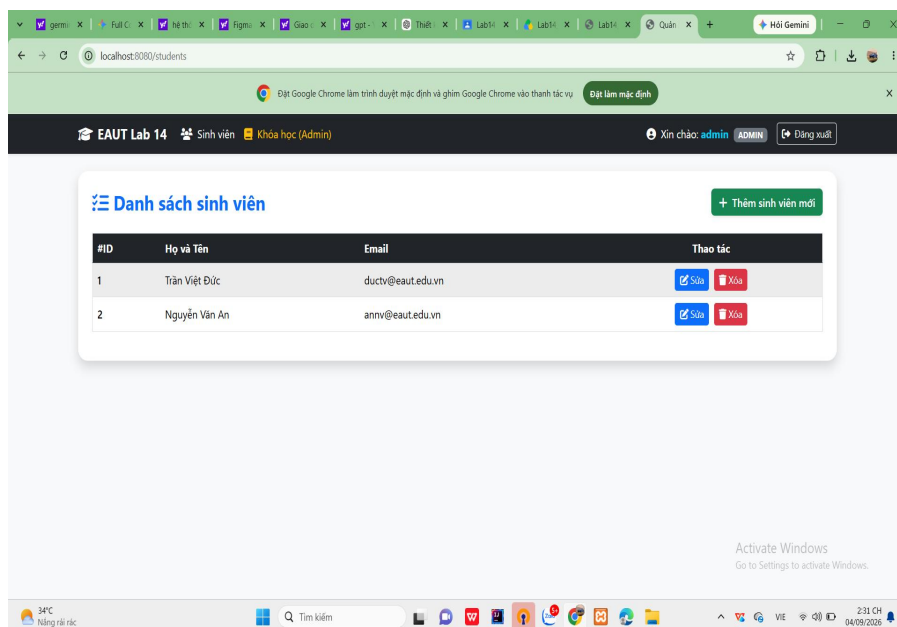


Các nút thao tác (Thêm, Sửa, Xóa) và menu quản lý khóa học bị ẩn hoàn toàn để bảo vệ dữ liệu hệ thống.

Đăng nhập với tài khoản admin:

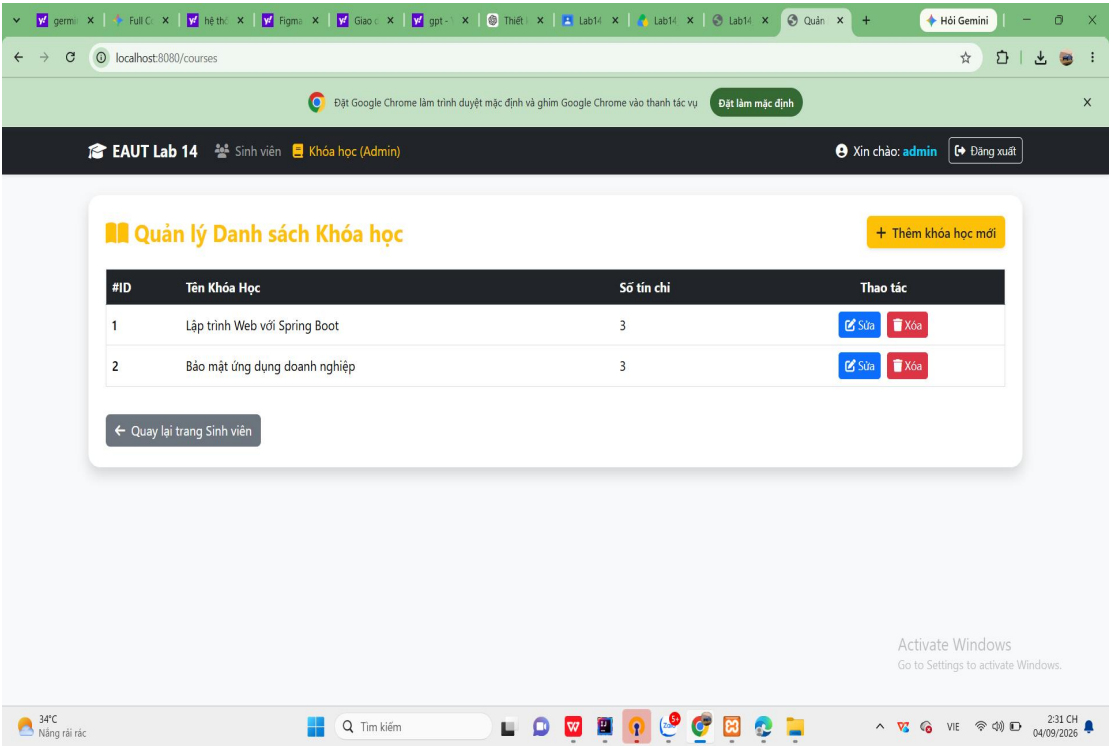


Giao diện hiển thị toàn quyền quản trị.

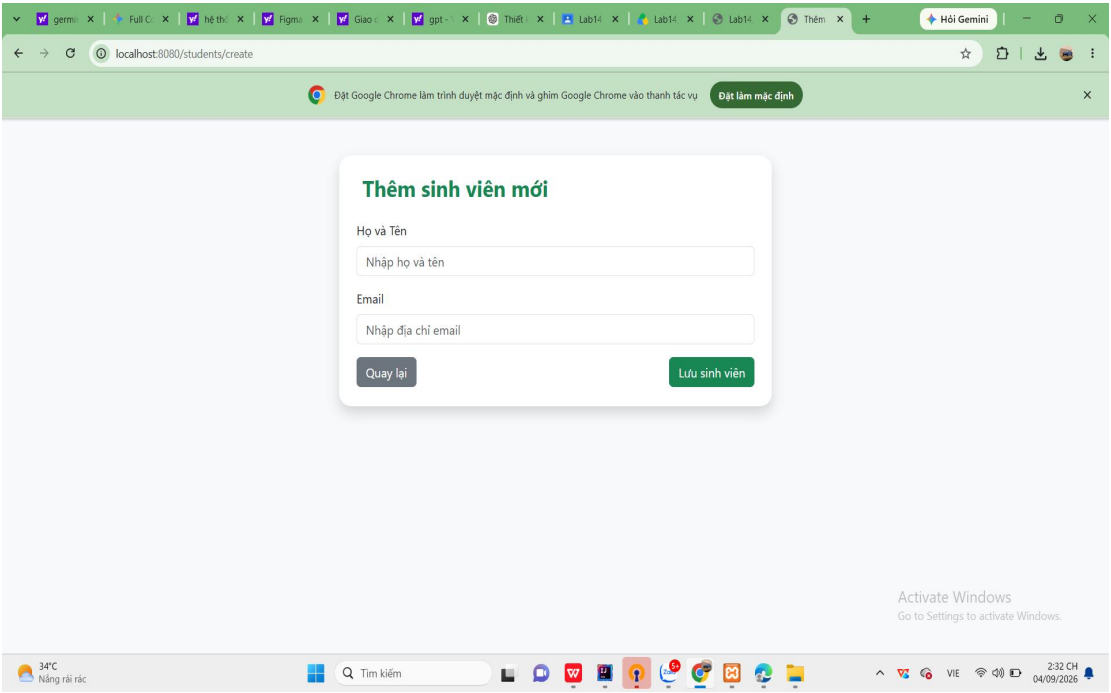


Xuất hiện đầy đủ nút "Thêm sinh viên mới", các tùy chọn Sửa/Xóa trên từng dòng dữ liệu, và menu "Khóa học (Admin)".

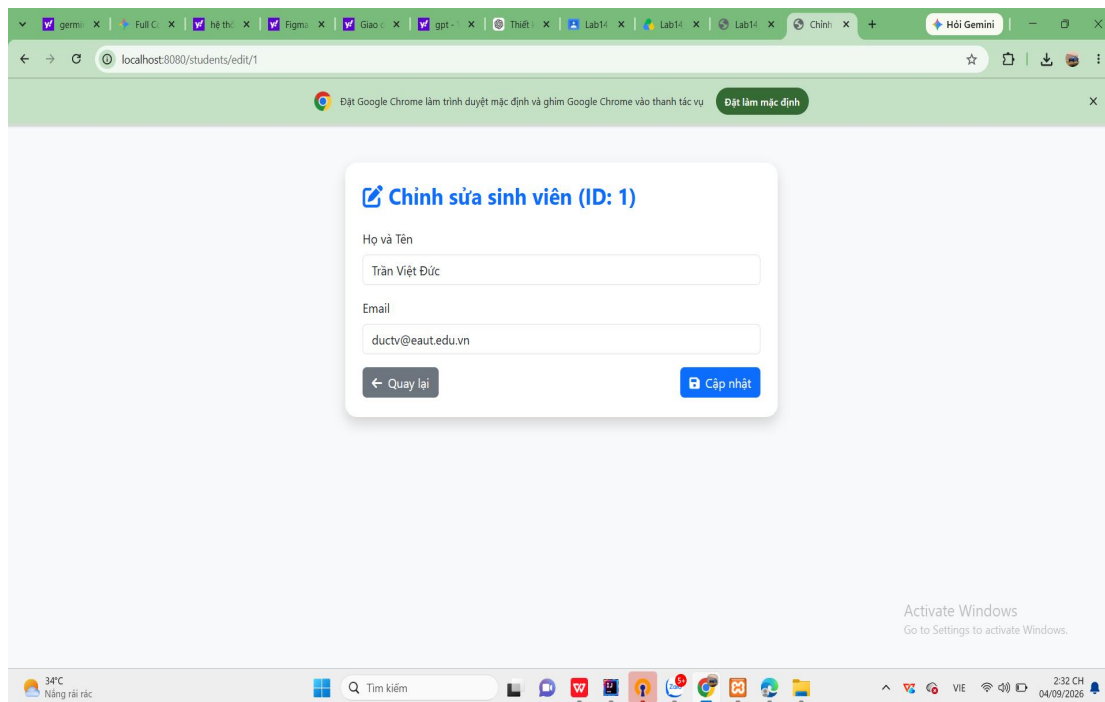
Khóa học



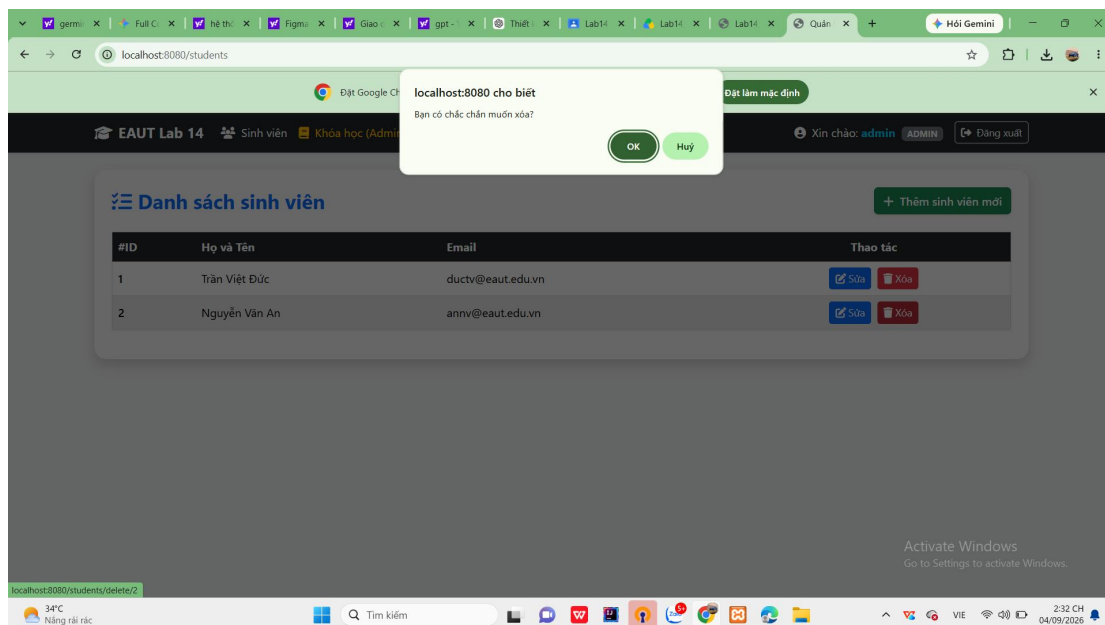
Thêm sinh viên



Sửa



Xóa



Xử lý ngoại lệ: Khi tài khoản user cố tình gõ đường dẫn cấm trên thanh địa chỉ, hệ thống lập tức chặn lại và chuyển hướng mượt mà về trang thông báo lỗi 403.

5. Kết luận

Bài lab đã hoàn thành xuất sắc các yêu cầu đề ra, giúp nắm vững cơ chế vận hành của Spring Security 6 trong việc bảo mật ứng dụng web Spring Boot. Hệ thống phân quyền hoạt động ổn định, giao diện trực quan, bảo đảm an toàn dữ liệu và đáp ứng toàn diện tiêu chuẩn đánh giá của học phần Công nghệ Java.